PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Identification du cœur de confiance

03-140 ANSSI - Cœur de confiance — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le cœur de confiance regroupe les ressources dont la compromission permet une prise de contrôle étendue du système d'information.
2. L'identification repose sur l'analyse des chemins de contrôle où une ressource gère légitimement une autre, et des chemins d'attaque par vulnérabilité.
3. La démarche doit être itérative car le périmètre évolue à chaque analyse ou action de sécurisation au lieu d'être un inventaire ponctuel.

Méthodologie d'identification du cœur de confiance

Notion	À retenir
Périmètre initial	Identifier les ressources de **gestion centralisée** (ex: **contrôleurs de domaine Active Directory**). Ce périmètre n'est **pas exhaustif**.
Chemins de contrôle/attaque	**Contrôle** : ressource A gère légitimement B. **Attaque** : compromission de A entraîne la compromission de B (vulnérabilités, configuration, profil attaquant).
Réajustement itératif	Le périmètre **grandit** (ressources contrôlant le cœur rejoignent le périmètre) ou **réduit** (sécurisation, durcissement, suppression de droits).
Aides à l'identification	Utiliser des **connaissances technologiques**, des **prestataires qualifiés ANSSI**, des outils (**BloodHound**, **PingCastle**, **OSAKA**) ou les **services d'audit de l'ANSSI**.

Exemples de cœurs de confiance

Notion	À retenir
SI Active Directory	Contrôleurs de domaine, postes d'administration/rebonds, **WSUS**, **AD-CS**, hyperviseurs, **AD-FS**, **Microsoft Entra Connect**, sauvegardes sensibles, agents de gestion (antivirus, EDR, déploiement). Assimilé au **Tier 0**.
SI industriel	Serveurs **SCADA** centraux, serveurs **MES** (depuis l'**ERP**) et ressources dépendantes. Si membres d'un domaine **Active Directory**, inclure le cœur de confiance de cet environnement.

Sécurisation du cœur de confiance

Notion	À retenir
Réduction et durcissement	Réduire au **strict minimum** la surface d'attaque, traiter un maximum de **chemins d'attaque et de contrôle**, et assurer que chaque ressource est **sécurisée, durcie et supervisée**.
Délégation et cloisonnement	Mettre en œuvre une **délégation fine** (peu d'administrateurs, actions peu fréquentes) et utiliser des **systèmes/comptes dédiés**, cloisonnés sur un **réseau ou VLAN dédié et finement filtré**.
Risques de sous-traitance	Maîtriser les **risques spécifiques** liés à la sécurité des **systèmes d'information des prestataires** lorsque la gestion est sous-traitée.

Pièges et confusions

⚠ Considérer le cœur de confiance comme un inventaire figé et ponctuel.
⚠ Confondre un chemin de contrôle (gestion légitime) avec un chemin d'attaque (compromission par vulnérabilité).
⚠ Oublier que l'assimilation au Tier 0 permet de réutiliser les principes de séparation des niveaux d'administration.
⚠ Négliger l'évolution du périmètre lors des phases de sécurisation ou de durcissement.

Sigles et définitions

Cœur de confiance	Ensemble des ressources informatiques dont la compromission pourrait mener à la prise de contrôle étendue du système d'information.
Chemin de contrôle	Existe lorsqu'une ressource A gère légitimement une ressource B.
Chemin d'attaque	Existe lorsque la compromission d'une ressource A entraîne la compromission vraisemblable d'une ressource B.
Tier 0	Niveau auquel le cœur de confiance d'un système d'information Windows peut être assimilé.
BloodHound	Outil en sources ouvertes permettant l'analyse automatique des chemins de contrôle d'un annuaire Active Directory.
OSAKA	Outil d'analyse automatique des chemins de contrôle pour une infrastructure Kubernetes.
SCADA	Serveur central qui pilote la majorité des automates programmables industriels, ou PLC, dans un système d'information industriel.
MES	Manufacturing Execution System, transmet des commandes aux serveurs SCADA à partir des données d'un ERP.

Auto-test

1. Qu'est-ce qu'un chemin de contrôle ?
2. Quel outil permet l'analyse automatique des chemins de contrôle pour Kubernetes ?
3. À quoi correspond le Tier 0 dans le modèle de Microsoft ?
4. Quelle est la fonction du serveur MES ?
5. Que se passe-t-il pour le périmètre du cœur de confiance après une action de sécurisation ?

Réponses : **1.** Une ressource A qui gère légitimement une ressource B. · **2.** OSAKA. · **3.** Au niveau auquel le cœur de confiance d'un système d'information Windows peut être assimilé. · **4.** Transmettre des commandes aux serveurs SCADA à partir des données d'un ERP. · **5.** Le périmètre peut être réduit.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.